

NETWORK SECURITY

Mg. Ing. CIP Adolfo Cáceres Luque



Universidad
Tecnológica
del Perú

Introducción al Network Security

Unidad 2 – Semana 4



Universidad
Tecnológica
del Perú

Logro de la sesión



- Al finalizar la sesión el estudiante conocerá la aplicación del protocolo RADIUS y DIAMETER en una red corporativa.

Temas a tratar

- Protocolo RADIUS
- Protocolo DIAMETER



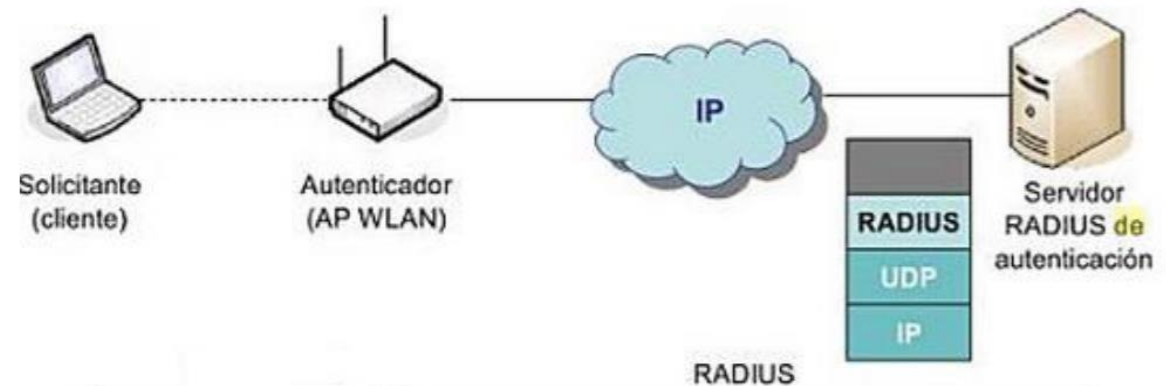
PROTOCOLO RADIUS

Es el acrónimo en inglés de Remote Authentication Dial-In User Server, y es quizás el más conocido. Utiliza el puerto UDP 1812 UDP y funciona como cliente-servidor. Su éxito residió, probablemente, en su implementación en proveedores de acceso a Internet (ISP), que fueron los que primero debieron incluir una instancia de autenticación remota a través de la red para validar las conexiones de sus clientes.

El servidor RADIUS verifica que esa información sea correcta usando esquemas de autenticación como PAP, CHAP o EAP. Si es aceptada, el servidor autorizará el acceso al sistema del ISP y seleccionará una dirección IP, parámetros L2TP, etc.

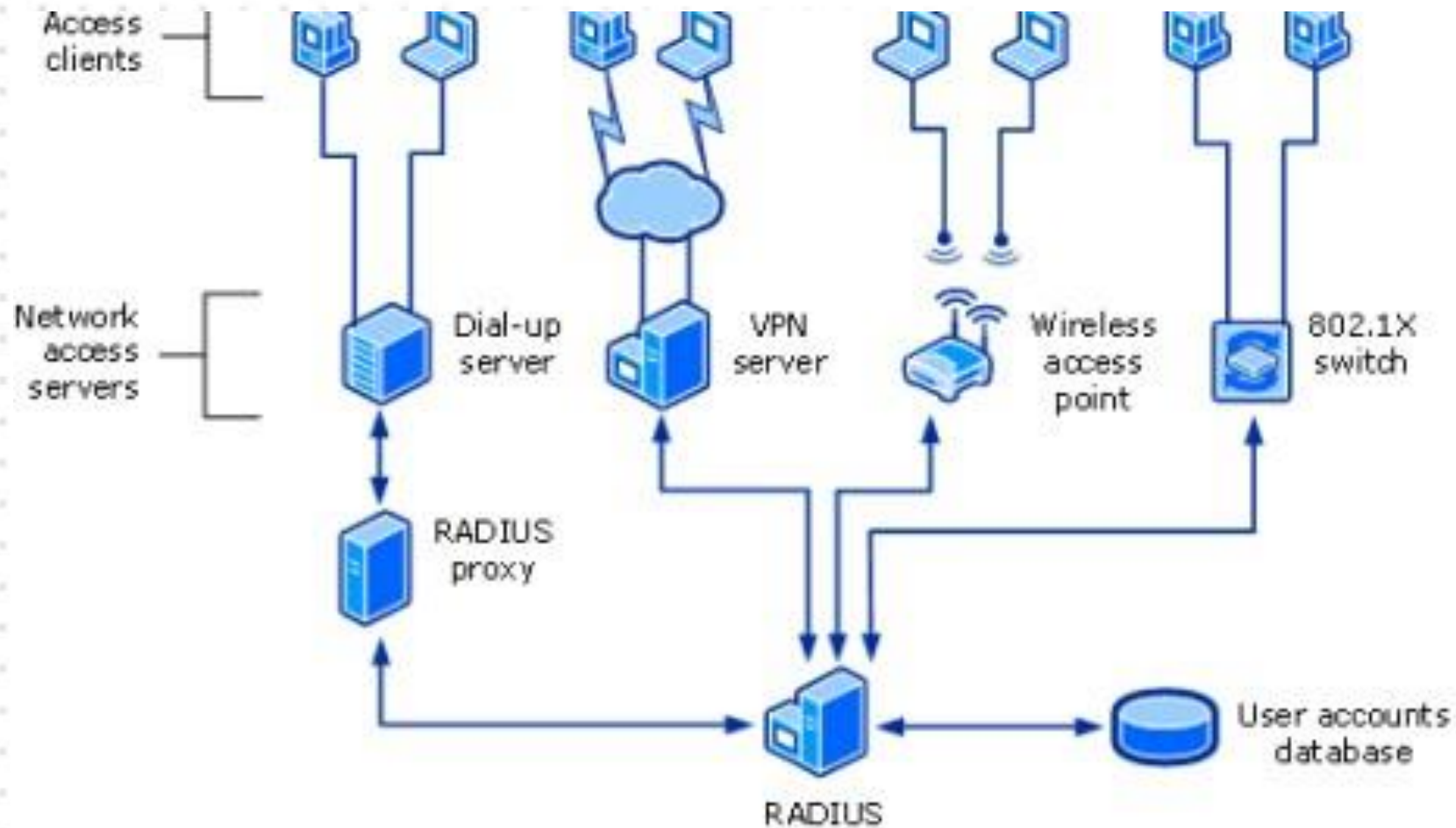
RADIUS también es comúnmente usado por el **NAS** para notificar eventos como:

- El inicio de sesión del usuario.
- El final de sesión del usuario.
- El volumen de datos transferidos durante la sesión.
- El total de paquetes transferidos durante la sesión.
- La razón para la terminación de la sesión



PROTOCOLO RADIUS

Infraestructura



Funcionamiento del Protocolo RADIUS

- ☐ La comunicación entre un servidor de acceso de red (NAS) y el servidor RADIUS se basa en el protocolo de datagrama de usuario (UDP). Por lo general, el protocolo RADIUS se considera un servicio sin conexión.
- ☐ RADIUS es un protocolo entre cliente y servidor. El cliente RADIUS suele ser un NAS y el servidor RADIUS suele ser un proceso de daemon que se ejecuta en una máquina con UNIX o Windows NT.
- ☐ El cliente traspasa información del usuario a servidores RADIUS designados y actúa según la respuesta recibida.
- ☐ Los servidores RADIUS reciben las solicitudes de conexión del usuario, autentican al usuario y devuelven la información de configuración necesaria para que el cliente pueda prestarle el servicio al usuario.
- ☐ Un servidor RADIUS puede funcionar como cliente proxy para otros servidores RADIUS u otro tipo de servidores de autenticación.

RADIUS está compuesto de **3 elementos**

- El Protocolo (utiliza los formatos de UDP/IP)
- Servidor
- Cliente

¿En cuales servicios se puede implementar RADIUS?

Acceso Inalámbrico

Es posible configurar puntos de acceso inalámbricos con 802.1X y aprovechar los servicios AAA para el control de acceso a la WLAN basada en 802.11, así como para proporcionar la administración de claves.

Acceso a VPN

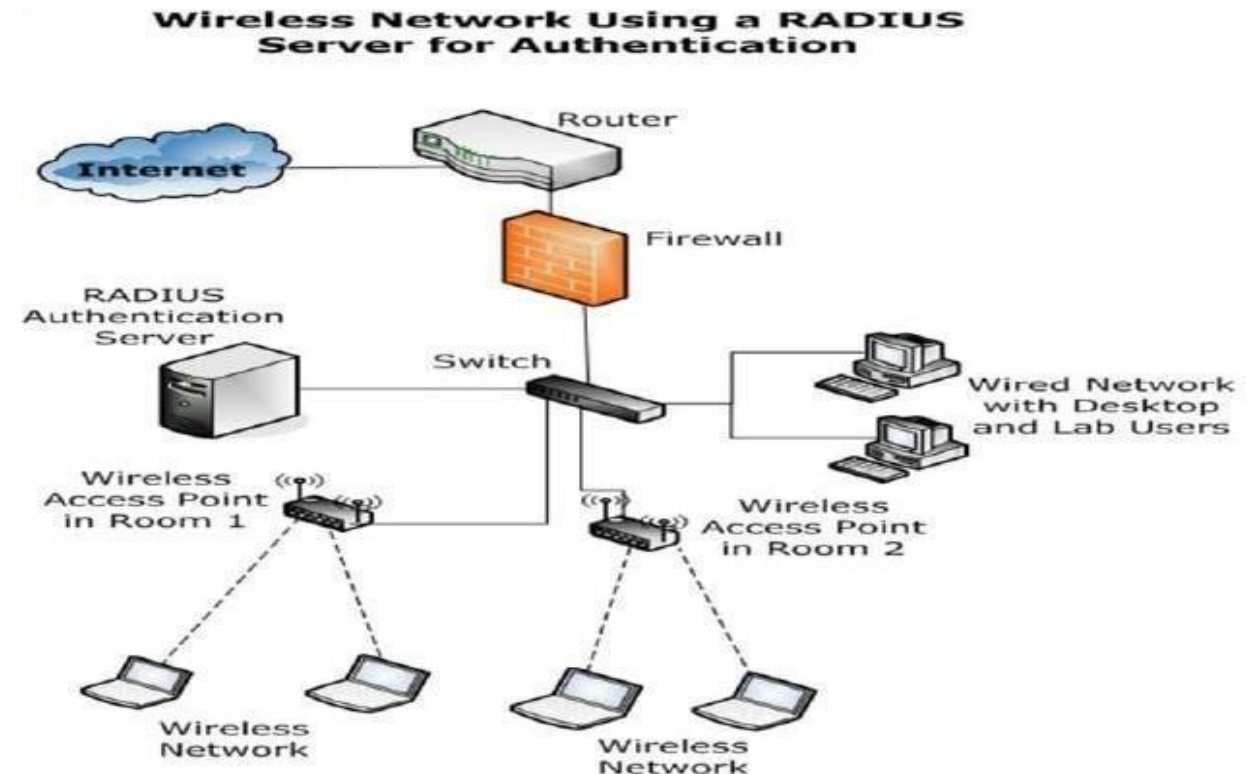
Los servidores VPN como RRAS basado en Windows pueden utilizar los servicios AAA de IAS para el control de acceso a la red corporativa, así como para proporcionar la administración de claves.

Acceso telefónico

Los servidores de acceso telefónico como RRAS basado en Windows pueden usar los servicios AAA RADIUS para el control de acceso a la red corporativa

Acceso a la extranet

Los servidores de acceso a la extranet pueden aprovechar los servicios AAA de RADIUS cuando se proporciona acceso restringido a los recursos compartidos.



Acceso a internet

Los proveedores de servicios de internet (ISP) pueden aprovechar los servicios AAA de RADIUS para proporcionar acceso a internet telefónico y de alta velocidad mientras emplean las bases de datos de cuentas y directivas de control de acceso organizativas individuales.

Esquemas de autenticación de Radius Base de datos de

Sistema

Las claves y logins almacenados en el servidor (ejemplo "normal" usuario de sistema UNIX, en Windows la información se puede obtener del AD (Active directory).

Base de datos interna

El login y el usuario es almacenado en una base de datos interna del servidor RADIUS. El password es almacenado utilizando MD5 o DES hash, whichever. en el algunos casos dependiendo la alternativa podría guardarse en texto plano.

Autenticación SQL

La información detallada del usuario se guarda en una base de datos SQL. La estructura de la base de datos es determinada por el administrador.



Autenticación y Autorización



El servidor RADIUS puede soportar varios métodos para autenticar un usuario. Cuando se le proporciona el nombre de usuario y la contraseña original aportados por el mismo, puede admitir PPP, PAP o CHAP, el inicio de sesión de UNIX y otros mecanismos de autenticación.

Comúnmente, el ingreso de un usuario al sistema consiste en un pedido (Solicitud de acceso) desde el NAS hacia el servidor RADIUS y de una correspondiente respuesta (Aceptación de acceso o Rechazo de acceso) desde el servidor.

El paquete de solicitud de acceso contiene el nombre de usuario, la contraseña cifrada, la dirección IP de NAS y el puerto.

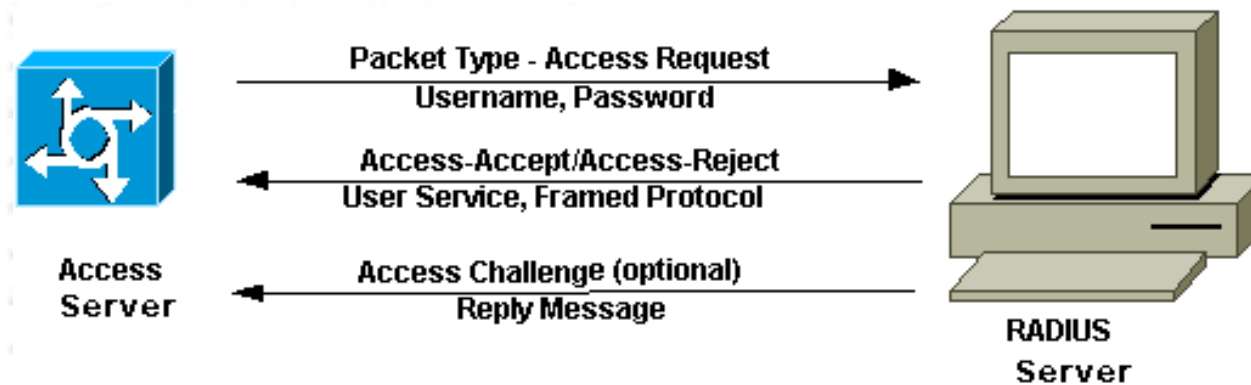
Cuando el servidor RADIUS recibe la solicitud de acceso del NAS, busca en una base de datos el nombre de usuario indicado. Si el nombre de usuario no existe en la base de datos, se carga un perfil predeterminado o el servidor RADIUS inmediatamente envía un mensaje Access-Reject (acceso denegado). Este mensaje de acceso rechazado puede estar acompañado de un mensaje de texto que indique el motivo del rechazo.

Autenticación y Autorización (cont.)

En RADIUS, la autenticación y la autorización están unidas. Si se encuentra el nombre de usuario y la contraseña es correcta, el servidor RADIUS devuelve una respuesta de Acceso-Aceptar e incluye una lista de pares de atributo-valor que describe los parámetros que deben usarse en esta sesión.

Los parámetros comunes incluyen el tipo de servicio, el tipo de protocolo, la dirección IP para asignar el usuario (estática o dinámica), la lista de acceso a aplicar o una ruta estática para instalar en la tabla de ruteo de NAS.

La información de configuración en el servidor RADIUS define qué se instalará en el NAS. La siguiente figura ilustra la secuencia de autenticación y autorización de RADIUS.



Contabilidad (Accounting)



- ☐ La funciones de contabilidad del protocolo RADIUS pueden emplearse independientemente de la autenticación o autorización de RADIUS. Las funciones de contabilidad de RADIUS permiten que los datos sean enviados al inicio y al final de las sesiones, indicando la cantidad de recursos (por ejemplo, tiempo, paquetes, bytes y otros) utilizados durante la sesión.
- ☐ Un Proveedor de servicios de Internet (ISP) puede usar RADIUS para el control de acceso y un software de contabilidad para satisfacer necesidades especiales de seguridad y facturación.
- ☐ Las transacciones entre el cliente y el servidor RADIUS son autenticadas mediante el uso de un secreto compartido, que nunca se envía por la red.
- ☐ Además, las contraseñas de usuario se envían cifradas entre el cliente y el servidor RADIUS para eliminar la posibilidad de que alguien que realiza snooping en una red insegura pueda determinar la contraseña de un usuario.

Ventajas del Servidor Radius

1. Mejora la seguridad de la red.
2. Mejora el seguimiento de los accesos a la red basado en los nombres de usuarios de clientes.
3. Permite aplicar restricciones a un usuario concreto.
4. Los accesos a la red individuales están encriptados.
5. Es posible desconectar a un único usuario o dispositivo sin afectar al resto, sin cambiar la clave del resto.

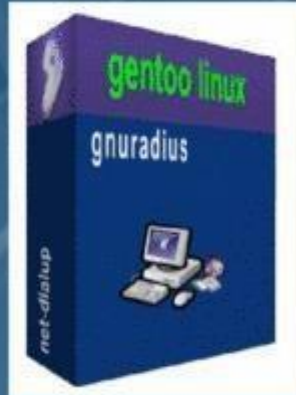
Desventajas del Servidor Radius

Como MD5 no es considerado como un sistema de protección de credenciales muy seguro, se aconseja hacer uso de otros sistemas adicionales para protección y cifrar el tráfico de RADIUS, como puede ser túneles de IPsec.

Soluciones RADIUS

Software Open source

- FreeRADIUS
- GNU Radius
- JRadius
- OpenRADIUS
- Cistron RADIUS
- XTRadius
- YardRadius
- BSDRadius



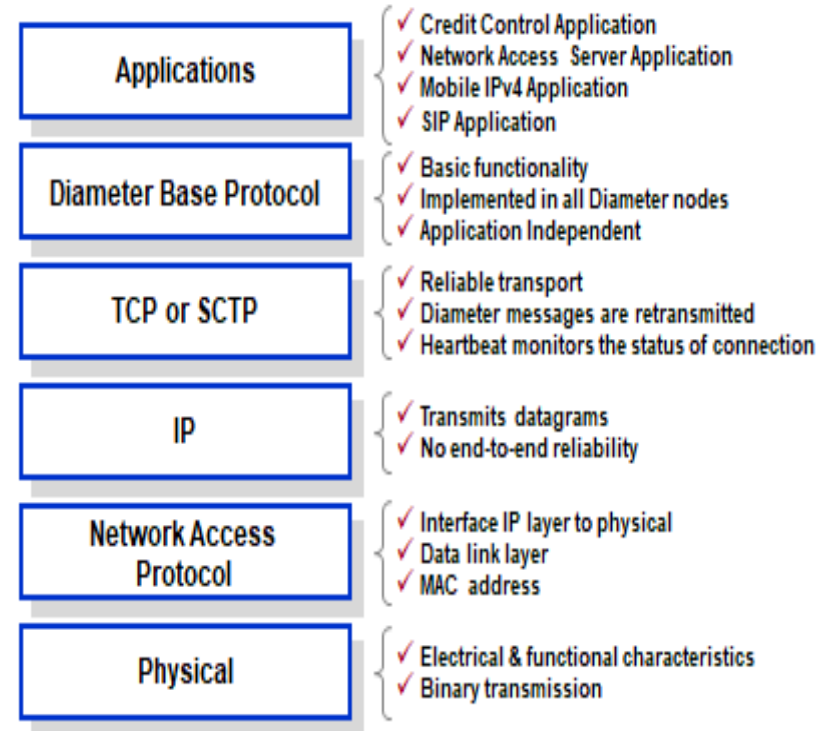
Software Comerciales

- Internet Authentication Service, included with server editions of Microsoft Windows.
- Cisco Secure Access Control Server
- Interlink Networks RAD-Series RADIUS Server
- Alepo Radius Server
- Steel-Belted Radius
- RadiusNT

PROTOCOLO DIAMETER

- Protocolo de capa de aplicación (según modelo OSI)
- Proveedor marco **AAA** para aplicaciones:
 - A** = autenticación, **A** = autorización,
A = contabilidad
- Sucesor del protocolo **RADIUS**
- El protocolo diameter es un protocolo basado en mensajes (paquetes).
- Hay dos tipos de mensajes: Solicitar mensaje (Request Messages) y Responder mensajes (Answer Messages).

Diameter Base Protocol Stack



PROTOCOLO DIAMETER



- ❑ **DIAMETER** es un protocolo de red, diseñado para suministrar un marco de trabajo que ofrezca servicios AAA para aplicaciones que involucren acceso a redes o aplicaciones IP Móvil.
- ❑ Diameter es un protocolo cuyo desarrollo se ha basado en el protocolo RADIUS, esta estandarizado de acuerdo con el RFC 6733 “Diameter Base Protocol”.
- ❑ En dicho RFC, se establecen las bases de Diameter y sólo se especifica el soporte para Accounting, aunque el concepto básico de Diameter es permitir que pueda ser extendido para proporcionar servicios de Authentication y Authorization.
- ❑ Diameter está diseñado para trabajar tanto de una manera local como en un estado de alerta, sondeo y captura, que en inglés se le denomina roaming de AAA, que permite ofrecer servicios sumamente móviles , dinámicos , flexibles y versátiles.
- ❑ Es un protocolo peer-to-peer, en el sentido que cada nodo puede iniciar una solicitud o request. Debido a esta característica peer-to-peer, todos los nodos que implementan Diameter pueden ser clientes, servidores o agentes Diameter.

Mejoras respecto al Protocolo Radius



- Usa protocolos de transportes fiables (TCP o SCTP, no UDP).
- Usa seguridad a nivel de transporte (IPSEC o TLS).
- Tiene compatibilidad transicional con RADIUS.
- Es un protocolo peer-to-peer en lugar de cliente-servidor: admite mensajes iniciados por el servidor.
- Admite ACKs en el nivel de aplicación, definiendo métodos de fallo.
- Tiene notificación de errores.
- Tiene mejor compatibilidad con roaming.
- Es más fácil de extender, pudiendo definirse nuevos comandos y atributos.
- Incluye una implementación básica de sesiones y control de usuarios.

Servicios AAA



☐ Autenticación

Existen autenticación de usuario, autenticación de equipo, autenticación de Mensaje, autenticación unilateral, autenticación mutua, autenticación server, etc.

☐ Autorización

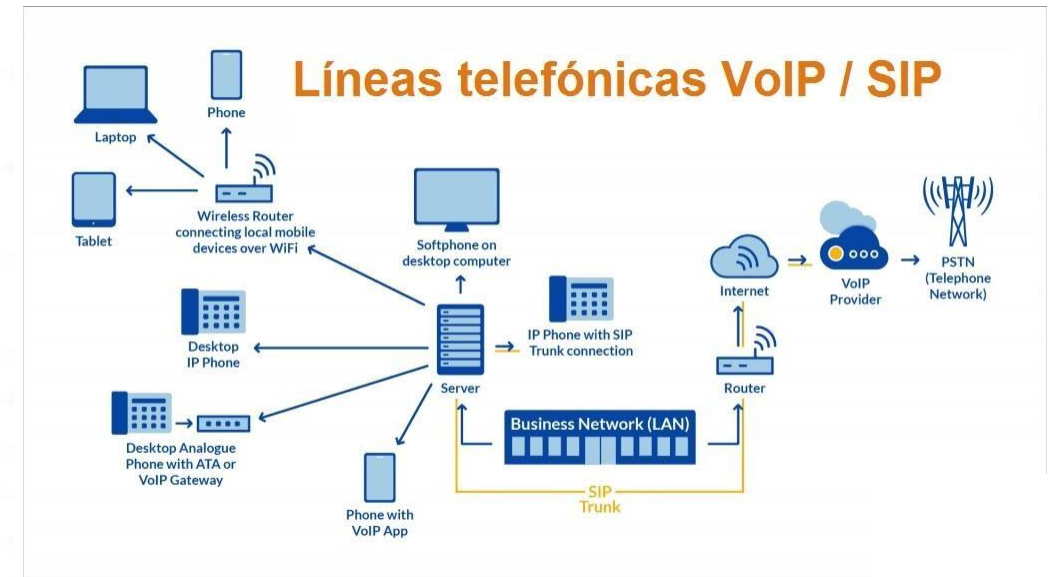
Los privilegios se asocian al perfil del usuario del terminal. Los privilegios pueden ser permitir el acceso a una serie de recursos, como bases de datos, archivos, acceso a periféricos, tiempo de uso de un procesador, ejecución de ciertas instrucciones etc.

☐ Contabilización

Es el proceso de recolección de información sobre el uso de recursos con el fin de realizar otras funciones como planificación de capacidad, auditorías, facturación y asignación de costos. La auditoría consiste en el chequeo periódico para determinar la firmeza de la información y de las políticas de gestión, en especial sobre la seguridad. La asignación de costos trata sobre la estructura de costos para cada uno de los servicios de los usuarios.

Aplicaciones

- Aplicaciones móviles IPv4 (MobileIP, RFC 4004).
- Aplicación de servidor de acceso a red (NASREQ, RFC 4005).
- Aplicación de protocolo extensible de autenticación (EAP) (RFC 4072).
- Aplicación de control de crédito (DCCA, RFC 4006).
- Aplicación de protocolo de inicio de sesión (SIP) (RFC 4740).



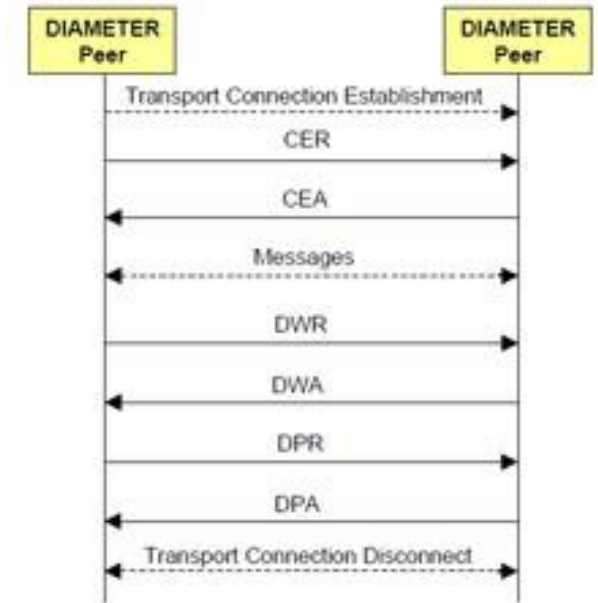
Seguridad en Diameter

- ☐ Se basa en IPsec o TLS para ofrecer seguridad.
- ☐ Es escalable y flexible.
- ☐ Permite definir nuevos comandos, atributos y aplicaciones.
- ☐ Admite múltiples mecanismos de autenticación y autorización.
- ☐ Proporciona seguridad de extremo a extremo.
- ☐ Admite mensajes iniciados por el cliente y por el servidor.



Flujos de mensajes en Diameter

- ❑ El protocolo DIAMETER usa los protocolos TCP o SCTP para el transporte por el puerto 3868.
- ❑ El flujo de mensajes en una conexión Diameter empieza con el establecimiento de la conexión. Después el que inicia la conexión envía un mensaje de Solicitud e Intercambio de Capacidades (CER), el receptor de este mensaje responde con un mensaje de respuesta de intercambio de capacidades (CEA), de forma opcional se puede negociarse si se desea TLS.
- ❑ La conexión ya está establecida y lista para el intercambio de mensajes de aplicación. Si durante un intervalo de tiempo, no se intercambian mensajes uno de los dos extremos enviará una solicitud de dispositivo “perro guardián” (DWR) y el otro responderá con una respuesta al dispositivo “perro guardián” (DWA). Cuando uno de los dos extremos desee finalizar la conexión, enviará un mensaje de solicitud de desconexión (DPR). Por último se responde al mensaje (DPR) con un mensaje (DPA) para dar por finalizada la conexión.



Conclusión

- Aplicar los protocolos RADIUS y DIAMETER genera un beneficio a las organizaciones a controlar y monitorear las acciones de sus usuarios de forma rápida y segura mediante la ayuda de los protocolos AAA.

Actividad

- ☐ Realizar un cuadro comparativo entre el Protocolo Radius y Diameter.
- ☐ Realizar el laboratorio de protocolos de autenticación AAA asignado por el docente.



Universidad
Tecnológica
del Perú



Universidad
Tecnológica
del Perú

Gracias!

Desaprende lo que te limita



**Universidad
Tecnológica
del Perú**